

作业 6：隐私原则

《负责任人工智能：原则、治理与量化方法》

黄斐，新南威尔士大学

姓名：林富强 专业：软件工程

问题一：一个场景，两种框架

a. 所选场景：健身应用 Strava 与全球热力图

场景描述：健身社交应用 Strava 允许用户通过手机和 GPS 运动手表上传跑步、骑行的轨迹，其声称的收集目的是“记录与分析个人运动表现，并与用户自己选择的好友在平台内分享”。2018 年，Strava 发布了“全球热力图”（Global Heatmap），把自 2011 年以来累计约 10 亿次活动、数万亿个 GPS 数据点聚合为一张任何人都能在线浏览的公开强度图；随后它又将聚合数据共享给城市交通规划机构用于“城市规划”。同年 1 月，澳大利亚国防分析师 Nathan Ruser 发现，这张热力图在叙利亚、阿富汗等偏远地区清晰勾勒出了美军海外基地的内部布局、巡逻路线与外出频率——用户为记录自己的锻炼而共享的数据，最终以全球公开发布和市政规划的形式被挪作他用。

b. Solove 分类法：至少三种具体隐私危害

运用 Solove（2006）的隐私侵害分类体系，该场景中至少存在以下四类具体危害（超出四个大类层面的具体名称）：

- **监视（surveillance）：**应用在每一次训练中持续记录用户的位置、路线与时段。这种追踪本身即是一种收集层面的侵害——它所揭示的信息（作息规律、常去地点、居家与工作位置）远超“运动表现”本身。
- **聚合（aggregation）：**数万亿个各自无害的单点 GPS 坐标，被组合成一张揭示性画像。任何一个孤立的位置点都不构成敏感信息，但聚合之后，热力图暴露了本应保密的军事基地轮廓与巡逻模式——聚合是本案例中后果最严重的一类侵害，与讲义中“各自无害的数据点组合后揭示任何单点都不会披露的敏感属性”的定义完全吻合。
- **二次使用（secondary use）：**为“个人运动记录与平台内社交分享”收集的数据，被挪用于用户从未预期、也从未同意的两个新目的——面向全球公众的公开发布与面向政府机构的商业规划产品。这正是 GDPR 第 5 条“目的限制”原则所禁止的流动。

• **提高可获取性（increased accessibility）**：此前仅存于用户个人账户、按隐私设置仅好友可见的轨迹，变成了全球任何人可搜索、可缩放、可按坐标定点查看的公开图像。信息内容未变，但其“可获取性”发生了质变——从需要授权访问，变为无需任何门槛的世界级公开。此外还可识别出**曝光（exposure）**——揭露军事人员绝无意愿公开的敏感信息（基地位置与人员活动节奏），并造成了现实的安全后果。

c. Nissenbaum 情境完整性分析

数据最初被收集时所处的情境，是**自我量化与运动社交**情境。按 Nissenbaum 的五个参数刻画其规范：

参数	用户共享数据时所预期的（原情境规范）	热力图事件中实际发生的
数据主体	我，Strava 用户	同一批用户（正确，未变）
发送方	我本人，主动上传自己的运动轨迹	Strava 以聚合后的数据产品形式代为发布
接收方	Strava 平台，以及我自行选择可见性的好友	全球任何能上网的人；以及市政规划机构等第三方
信息类型	我个人的运动 GPS 轨迹（自披露的运动数据）	聚合的人群活动强度地图（实质揭示群体行为模式）
传输原则	“为记录与分析我的运动”在平台内存储与分享，受我的隐私设置约束	公开出版物与商业数据产品，无需任何授权或同意

五个参数中，**接收方、信息类型与传输原则**三项均被违反：接收方从“平台与自选好友”扩张为“全球任何人”；传输原则从“受隐私设置约束的平台内使用”变为“面向公众的无条件发布”。

为何即使数据已被聚合、无法识别任何个人，仍构成违规？情境完整性理论的核心主张是：隐私关乎**信息流动**是否符合**数据被共享时所处情境**的规范，而非流动是否泄露了可识别个体的记录。用户在原情境中依循的规范是“我为了记录锻炼而共享数据”，与之相符的流动是平台存储与自选好友可见；而热力图把同一批数据推向全球公众与政府机构，这一流动违反了原情境的规范，侵害随之成立——危害只是落在了**群体层面**而非个体层面：热力图确实识别不出“张三”，但它揭示了“该基地每一条巡逻路线的位置与频次”。Nissenbaum 框架的检验很简单：共享这份数据的人，是否会预期它以这种方式流动？答案显然是否定的，因此即便发布物在技术上已聚合、已无法定向到个人，流动本身仍然是不恰当的。

d. 一项治理管控措施

提出“目的特定的二次同意 + 分级发布”管控：任何二次目的（公开研究、市政规划、商业合作）在新目的启动前，都触发一次独立的同意征集与发布审查流程——组织以清晰、非埋藏式告知说明新目的、新接收方与数据形式，仅向**主动选择加入（opt-in）**的用户收集的数据用于新目

的，默认状态是“不纳入”；同时对拟发布物进行分级处理：提高聚合粒度、剔除军政等敏感区域（类似 Strava 事后引入的 privacy zones）、延迟发布可被用于实时侦察的图层。

该措施之所以能让数据用于二次目的而不违反情境完整性，是因为它逐一修复了被违反的参数：**传输原则**被重新协商——新场景下的流动以用户对新目的明确同意为前提，与用户在原情境中的合理预期重新对齐；**接收方**被限定为同意所涵盖的接收方；**信息类型**经分级发布后不再超出原情境中“运动记录”所能揭示的范围。反之，若仅靠细则中默认勾选的宽泛授权（如 GM OnStar 的做法），传输原则参数依旧与用户预期不符，情境完整性依然被破坏。

问题二：选择隐私增强技术

所选领域：**保险**（承保与定价组合，可对应一家持有人寿与健康险种的保险公司）。针对四个数据共享场景逐一给出技术选型及效用—隐私权衡。

a. 内部分析团队需要完整的个体层级数据集来构建新模型

结论：四种技术均不适用（也不必要），正确的控制是治理性控制而非匿名化技术。理由：数据始终留在组织内部、用于其被收集的既定目的（承保建模），并不发生“对外共享”这一隐私风险事件——k-匿名性、差分隐私、合成数据解决的都是“数据被发布或共享后”的风险，联邦学习解决的是“数据不能集中”的问题，而此处数据本来就集中在一处。强行匿名化只会单方面损失效用：k-匿名性的泛化会抹平定价所必需的连续变量粒度（精确年龄、保额、人口密度），差分隐私的噪声会严重扭曲重尾的理赔分布（个别大额理赔正是精算建模的关键信息），合成数据则引入“模型学到的关系与真实关系不一致”的额外风险。

合适的做法是落实讲义中的核心原则：**数据最小化**（只保留建模必需字段）、**存储限制**、访问控制与加密（GDPR 第 5 条、APP 3/11）；若建模将由外部承包商参与，则把该场景降级为一次对外共享，改用合成数据或 DP-SGD（差分隐私训练）来限制个体记录的影响。

b. 业务合作伙伴要求组合层级/群组层级的数据集以支持具体业务决策

推荐技术：差分隐私（对所需汇总统计量采用拉普拉斯机制发布）。理由：对方明确不需要个体层级记录，只需要群组层面的统计量（如各风险段的理赔频率、平均赔付），这与 DP 的能力完全匹配——直接在汇总数字上加噪即可，无需发布任何记录。相比 k-匿名性，DP 提供正式的 ϵ -DP 数学保证：无论对方掌握何种背景信息，都无法把某个个体的记录从汇总结果中反推出来（这正是 k-匿名性给不了的保证——它只防“在数据集内部”被识别，防不住与外部信息结合的重建攻击）。

效用—隐私权衡：隐私预算 ϵ 越小隐私越强、噪声越大。用于再保险定价等组合级决策时，可承受的噪声相对汇总量级通常很小，选择 ϵ 在 1–10 区间即可在可用性与保护之间取得平衡；敏感度 Δf 高的统计量（如单笔大额理赔求和）噪声更大，可通过限制统计口径或分段发布来压低 Δf 。若未来需要发布更多张统计表，须按 DP 的可组合性累计扣除总预算，防止多次查询耗尽隐私。

c. 公开发布一个匿名化数据集以支持学术研究

推荐技术：合成数据（理想情况下经差分隐私训练的合成数据）。理由：学术研究需要记录层级的微观数据来拟合模型，k-匿名性虽然也发布记录，但其泛化会显著降低可用于建模的粒度与相关性结构，且不提供正式保证；DP 若直接用于发布统计量，则无法提供研究者需要的记录级数据集。合成数据生成全新记录、保留边际分布与联合关系（可用边际保真、联合保真与模型性能三方面评估），不存在任何一位真实个体的记录，与 IRS 统计所得司发布完全合成报税公用文件的做法同类。

效用—隐私权衡：合成数据并不自动保证隐私——生成模型可能产生记忆效应，将罕见或极端的真实记录近乎原样复现（如极端高龄 + 大额保单的组合）。因此工程上应叠加防护：发布前用最近邻距离比（NNDR）诊断合成记录与真实记录的相似度，或先对真实数据做 k-匿名/抑制处理再训练，或直接以 DP 约束训练过程，使发布物获得正式保证。保真度与隐私在此构成明确的张力：合成分布越贴近真实分布（含尾部），记忆与披露风险越高，需按用途（探索性研究 vs 精确重定价）设定折中点。

d. 多家机构希望联合训练共享模型，但均不得发送原始数据

推荐技术：联邦学习（并以差分隐私与安全聚合加固）。理由：这是唯一针对“数据不能集中”这一前提设计的技术——各保险公司在本地理赔数据上训练共享的欺诈检测模型，仅上传模型权重更新并汇聚平均（联邦平均），任何一条原始保单持有人记录都不离开本机构，与微众银行 FATE 联邦信用评分的生产部署属同一模式。前三种技术都默认数据先集中再保护，与该场景的前提直接冲突。

效用—隐私权衡：联邦学习保护的是数据的位置，而非内容本身——模型更新仍可能通过梯度反演等攻击泄露训练数据，因此生产部署应叠加 DP（对汇聚后的更新加噪）与安全聚合（服务器只见更新之和、不见单方贡献）。相比集中式训练，联邦配置在分布不一致、参与方可用性差异与工程协调上有额外成本，模型精度可能略降；换来的是各家在合规上（APP 6/8、GDPR 目的限制与第五章）都不必转移原始数据，这对受监管的保险公司往往是决定性收益。

场景	推荐技术	核心理由与权衡
a. 内部团队用个体级数据建模	四者均不适用	无对外共享即无发布风险；用最小化、访问控制等治理措施；强行匿名化只会损失建模效用
b. 伙伴要群组级数据	差分隐私	需求即汇总统计量，拉普拉斯机制直接匹配； ϵ 控制噪声，提供正式保证，防重建攻击
c. 公开发布学术数据集	合成数据（宜叠加 DP）	保留记录结构与统计关系供建模；须防记忆效应，用 NNDR/k-匿名/DP 训练兜底
d. 跨机构联合建模	联邦学习 + DP/安全聚合	原始数据不出机构；权重更新仍有泄露风险，需加噪与安全聚合，协调成本高于集中式

问题三：数据保护影响评估（DPIA）

场景设定：为一款基于远程信息处理的保险产品开展 DPIA——手机应用或联网设备持续收集驾驶行为数据（位置、速度、急刹车、时段）用于定价。DPIA 整体遵循 OAIC 的四阶段逻辑（识别 → 评估 → 建议 → 响应），并落实 GDPR 第 35 条与第 25 条“设计与默认的数据保护”。纳入的主要部分如下：

#	部分标题	内容说明（一句话）
1	项目概述与处理活动描述（识别）	映射完整数据流：收集哪些行为数据、来自哪些设备、出于何种目的、流向哪些系统与主体、谁有权访问，作为后续一切评估的事实基础。
2	法律依据与合规框架映射	对照 GDPR 第 5 条六原则、APP 1–13 与 PIPL 第 24 条，逐项确定每类处理活动的法律依据（同意/合同）与对应义务。
3	数据分类与敏感度分析	区分个人数据、敏感/特殊类别数据与衍生/推断数据（如驾驶行为评分），并识别准标识符组合，评估重新识别风险（Sweeney 的邮编+生日+性别教训）。
4	必要性与数据最小化评估	逐字段审查是否为定价目的所必需，剔除“以防万一”的收集项，并核实“隐私作为默认设置”是否落实（第 25 条、APP 3）。
5	利益相关方识别与咨询	征询数据主体代表、DPO 的意见，必要时依 GDPR 第 35(9) 条提前咨询监管机构，重点识别权力不对称与用户合理预期。
6	隐私风险识别与评估（评估）	用 Solove 分类法枚举具体危害（监视、聚合、二次使用、排斥等），用场景一致性五参数检验每次信息流动是否恰当，按可能性×严重性评级。
7	风险控制措施与隐私设计（建议）	落实第 25 条：选择适配的隐私增强技术（k-匿名、差分隐私、合成数据、联邦学习）、加密与访问控制、留存期限与自动删除。
8	自动化决策与透明度保障	若行为数据输入自动化定价决策，须配置第 22 条保障措施（人工干预、申诉）与第 13–15 条有意义解释，并参照 PIPL 第 24 条的拒绝权。
9	第三方共享与跨境传输评估	逐一审查下游接收方（经纪商、再保险人）与跨境流动，落实目的限制、APP 8 与 GDPR 第五章的同等保护要求——GM OnStar 案即为此部分的反面教材。
10	剩余风险记录、签署与持续复查（响应）	记录各项建议的采纳情况与剩余风险，由 DPO/高管签署确认，并建立泄露通知（如 PDPA 三日时限）与定期复查机制。

十项中，第 1-5 部分对应 OAIC 流程的“识别”，第 6 部分为“评估”，第 7-9 部分为“建议”，第 10 部分为“响应”；监管框架（GDPR、APP、PIPL）为第 2、7、8、9 部分提供直接依据，而隐私设计七原则（主动而非被动、默认隐私、端到端安全等）则贯穿第 4、7 部分——隐私考量应从模型开发流程之初就纳入，而非等到部署阶段才补审。